

802.1X, RADIUS, LDAP e autenticazione Wi-Fi Enterprise

Overview

Le reti Wi-Fi sono molto diffuse ma introducono problemi di sicurezza importanti.

In una rete cablata normalmente è necessario l'accesso fisico all'edificio.

Nel Wi-Fi il segnale radio può essere ricevuto anche all'esterno.

Per questo motivo l'autenticazione e la cifratura sono fondamentali.

Obiettivi della sezione

Comprendere:

- perché il Wi-Fi necessita di protezione;
- differenza fra autenticazione e cifratura;
- concetto di accesso autorizzato;
- differenza fra reti domestiche e reti enterprise.

Concetti fondamentali

Autenticazione

L'autenticazione serve a verificare l'identità di un utente o dispositivo.

Esempi:

- username e password;
- certificato digitale;
- smart card;
- token.

Autorizzazione

L'autorizzazione stabilisce quali risorse siano accessibili.

Esempio:

- uno studente può accedere solo alla VLAN studenti;
- un docente può accedere ai server interni.

Accounting

L'accounting consiste nella registrazione delle attività.

Esempi:

- orario di accesso;
- quantità di traffico;
- indirizzo IP assegnato.

Reti Wi-Fi domestiche

Nelle reti domestiche normalmente si utilizza:

- WPA2 Personal;
- WPA3 Personal.

In questi casi tutti condividono la stessa password.

Problemi:

- difficile revocare un singolo utente;
- impossibile distinguere gli utenti;
- scarsa tracciabilità;
- maggiore rischio di diffusione della password.

Reti Wi-Fi enterprise

Nelle reti enterprise ogni utente possiede credenziali individuali.

Vantaggi:

- autenticazione centralizzata;
- controllo utenti;
- logging;
- segmentazione della rete;
- revoca utenti singoli.

Schema

Client Wi-Fi



Access Point



Server RADIUS



LDAP / Active Directory

Attività consigliata: analizzare:

- differenze fra rete domestica e rete scolastica;
- vantaggi di credenziali individuali;
- rischi della password condivisa.

Sezione 2 — WPA Personal e WPA Enterprise

Overview

Le reti Wi-Fi moderne utilizzano standard WPA2 o WPA3.

Esistono due modalità principali:

- Personal;
- Enterprise.

WPA Personal

Utilizza:

- PSK;
- password condivisa.

PSK significa:

Pre-Shared Key

Tutti i dispositivi utilizzano la stessa chiave.

Funzionamento

Client



password Wi-Fi



Access Point

Nessun server centrale.

Limiti

- nessuna identità individuale;

- difficile gestione utenti;
- cambio password necessario per tutti;
- limitata scalabilità.

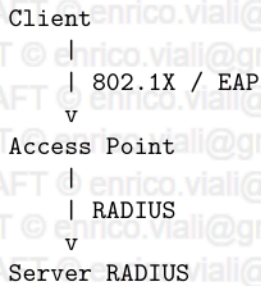
WPA Enterprise

Usa:

- 802.1X;
- RADIUS;
- EAP.

Ogni utente usa credenziali personali.

Schema



Differenze principali

Caratteristica	WPA Personal	WPA Enterprise
Password condivisa	sì	no
Utenti individuali	no	sì
Server RADIUS	no	sì
Logging utenti	limitato	avanzato
VLAN dinamiche	no	sì
Sicurezza	media	elevata

WPA3

WPA3 migliora:

- robustezza crittografica;
- protezione contro attacchi offline;
- sicurezza handshake.

Esiste sia:

- WPA3 Personal;
- WPA3 Enterprise.

Sezione 3 — Standard IEEE 802.1X

Overview

802.1X è uno standard IEEE per il controllo degli accessi di rete.

Serve a consentire l'accesso solo dopo autenticazione.

Componenti principali

Supplicant È il client che richiede accesso.

Esempi:

- notebook;

- smartphone;
- PC;
- stampanti.

Authenticator È il dispositivo che controlla l'accesso.

Esempi:

- switch;
- access point.

Authentication Server È il server che autentica.

Normalmente:

- server RADIUS.

Schema

Supplicant

|
EAPOL
v

Authenticator

|
RADIUS
v

Authentication Server

EAPOL EAPOL significa:

EAP over LAN

È il protocollo usato fra client e switch/access point.

Stati della porta Una porta 802.1X può essere:

- authorized;
- unauthorized.

Se unauthorized:

- passa solo traffico EAPOL.

Se authorized:

- passa traffico normale.

Sequenza semplificata

1. client collegato
2. porta bloccata
3. richiesta autenticazione
4. inoltro a RADIUS
5. verifica credenziali
6. autorizzazione accesso

Vantaggi

- sicurezza maggiore;
- autenticazione centralizzata;
- controllo accessi;
- logging.

Limiti

- maggiore complessità;
- necessità di server dedicati;
- configurazione più difficile.

Sezione 4 — RADIUS e AAA

Overview

RADIUS è il protocollo più usato per autenticazione centralizzata nelle reti.

AAA

AAA significa:

- Authentication;
- Authorization;
- Accounting.

Authentication

Verifica identità.

Esempio:

- username/password.

Authorization

Definisce permessi.

Esempio:

- assegnazione VLAN.

Accounting

Registra attività.

Esempio:

- tempo di connessione.

Architettura

Client

|

v

Access Point

|

RADIUS

v

Server RADIUS

Porte standard

Funzione	Porta UDP
Authentication	1812
Accounting	1813

Shared Secret

Access point e RADIUS condividono una chiave segreta.

Serve per:

- protezione comunicazione;
- verifica autenticità dei pacchetti.

Principali server RADIUS

- FreeRADIUS;
- Microsoft NPS;
- Cisco ISE.

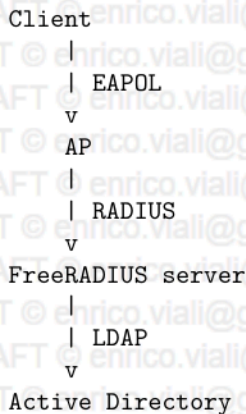
FreeRADIUS

FreeRADIUS è il server RADIUS open source più diffuso.

Caratteristiche:

- Linux;
- LDAP;
- Active Directory;
- SQL;
- EAP;
- VLAN dinamiche.

Flusso completo



Sezione 5 — LDAP e Active Directory

Overview

LDAP e Active Directory sono concetti collegati ma diversi.

LDAP

LDAP significa:

Lightweight Directory Access Protocol

È un protocollo standard.

Serve a:

- cercare utenti;
- leggere attributi;
- autenticare;
- organizzare directory.

Struttura gerarchica

Esempio:

```

dc=scuola,dc=local
|
+-- ou=docenti
|

```


+-- ou=studenti

Oggetti LDAP

Ogni oggetto possiede attributi.

Esempi:

- nome;
- email;
- password;
- gruppo;
- telefono.

Active Directory

Active Directory è il servizio directory Microsoft.

Usa:

- LDAP;
- Kerberos;
- DNS;
- Group Policy.

Relazione corretta

LDAP = protocollo

Active Directory = servizio directory

Active Directory NON è solo LDAP

Include:

- autenticazione dominio;
- gestione utenti;
- gestione computer;
- policy centralizzate;
- trust;
- replica.

LDAP sicuro

Per sicurezza si usa:

- LDAPS;
- StartTLS.

Schema tipico

FreeRADIUS

|

| LDAP / LDAPS

v

Active Directory

Sezione 6 — Integrazione Wi-Fi Enterprise

Overview

Una rete Wi-Fi enterprise integra:

- 802.1X;
- EAP;
- RADIUS;
- LDAP/AD.

Architettura completa

Smartphone / PC

| EAPOL

v

Access Point

|

| RADIUS

v

FreeRADIUS

|

| LDAP

v

Active Directory

Sequenza dettagliata

Fase 1

Il client si collega all'SSID.

Fase 2

L'AP richiede autenticazione 802.1X.

Fase 3

Il client invia credenziali EAP.

Fase 4

L'AP inoltra i dati a RADIUS.

Fase 5

RADIUS verifica le credenziali tramite LDAP.

Fase 6

Se corrette:

- accesso consentito.

Altrimenti:

- accesso negato.

VLAN dinamiche

Il server RADIUS può assegnare VLAN diverse.

Esempio:

Gruppo	VLAN
Docenti	10
Studenti	20
Ospiti	30

Benefici

- segmentazione;
- sicurezza;
- gestione centralizzata;
- tracciabilità.

Sezione 7 — Metodi EAP

Overview

EAP definisce diversi metodi di autenticazione.

EAP-TLS

Basato su certificati digitali.

Molto sicuro.

Richiede:

- certificato server;
- certificato client.

PEAP

Usa:

- tunnel TLS;
- username/password.

Molto diffuso in Windows.

EAP-TTLS

Simile a PEAP.

Molto usato con FreeRADIUS.

Confronto

Metodo	Sicurezza	Complessità
PEAP	buona	media
EAP-TTLS	buona	media
EAP-TLS	molto elevata	elevata

Certificati

Il certificato server è fondamentale.

Senza verifica certificato:

- rischio rogue access point;
- rischio furto credenziali.

Sezione 8 — VLAN dinamiche e controllo accessi

Overview

RADIUS può assegnare automaticamente VLAN diverse.

Vantaggi

- separazione traffico;
- maggiore sicurezza;
- gestione centralizzata.

Esempio scolastico

Categoria	VLAN
Laboratorio	10
Docenti	20

Categoria	VLAN
Segreteria	30
Ospiti	40

Decisione centralizzata

La decisione può dipendere da:

- gruppo LDAP;
- ruolo;
- certificato;
- dispositivo.

Schema

```

Utente
|
v
RADIUS
|
+--> VLAN 10
+--> VLAN 20
+--> VLAN 30

```

NAC

802.1X è spesso parte di sistemi NAC.

NAC significa:

Network Access Control

Permette:

- controllo dispositivi;
- verifica conformità;
- isolamento sistemi non sicuri.

Sezione 9 — Analisi del traffico e troubleshooting

Overview

Le reti 802.1X possono essere difficili da diagnosticare.

Problemi comuni

- password errata;
- certificato non valido;
- shared secret errata;
- LDAP non raggiungibile;
- orario non sincronizzato.

Strumenti

- Wireshark;
- log FreeRADIUS;
- log access point;
- tcpdump.

Traffico tipico

Protocollo	Uso
EAPOL	client ↔ AP

Protocollo	Uso
RADIUS	AP ↔ server
LDAP	RADIUS ↔ directory

Wireshark

Filtri utili:

eapol

oppure:

radius

Log FreeRADIUS

Comando:

`freeradius -X`

Avvia FreeRADIUS in modalità debug.

Molto utile per:

- errori autenticazione;
- problemi LDAP;
- problemi certificati.

Sezione 10 — Laboratorio pratico con FreeRADIUS

Overview

Configurazione base di laboratorio.

Obiettivi

Comprendere:

- struttura minima di una soluzione enterprise;
- configurazione base;
- flusso autenticazione.

Ambiente

- Ubuntu Server;
- FreeRADIUS;
- OpenLDAP oppure Active Directory;
- Access point compatibile WPA2 Enterprise.

Installazione FreeRADIUS

Ubuntu:

```
sudo apt update
sudo apt install freeradius
```

Avvio debug

```
sudo freeradius -X
```

Configurazione client RADIUS

File:

`/etc/freeradius/3.0/clients.conf`

Esempio:

```
client ap_scuola {
    ipaddr = 192.168.1.2
    secret = segretoRadius
}
```

Utente locale di test

File:

/etc/freeradius/3.0/users

Esempio:

```
student1 Cleartext-Password := "Password123"
```

Test locale

Comando:

```
radtest student1 Password123 localhost 0 testing123
```

Configurazione access point

Configurare:

- modalità WPA2 Enterprise;
- IP server RADIUS;
- porta 1812;
- shared secret.

Collegamento LDAP

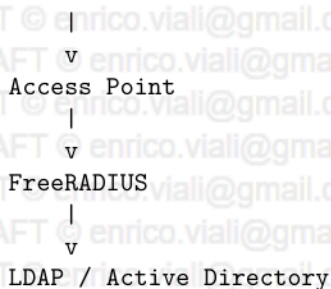
Installare modulo LDAP.

Configurare:

- indirizzo server LDAP;
- DN base;
- bind user;
- password bind.

Schema finale laboratorio

Notebook



Verifica finale

Domande teoriche

- differenza fra WPA Personal e WPA Enterprise;
- ruolo di RADIUS;
- differenza fra LDAP e Active Directory;
- funzione di 802.1X;
- ruolo di EAP;
- significato di AAA.

Attività pratiche

- interpretazione schema di rete;
- identificazione componenti;
- analisi log semplificati;
- progettazione rete scolastica.

Estensioni possibili

- integrazione con VLAN dinamiche;
- autenticazione cablata 802.1X;
- EAP-TLS con certificati;
- NAC avanzato;
- captive portal;
- autenticazione federata.

Glossario

Termine	Significato
AAA	Authentication, Authorization, Accounting
AD	Active Directory
AP	Access Point
EAP	Extensible Authentication Protocol
EAPOL	EAP over LAN
LDAP	Lightweight Directory Access Protocol
NAC	Network Access Control
PSK	Pre-Shared Key
RADIUS	Remote Authentication Dial-In User Service
WPA	Wi-Fi Protected Access
802.1X	Port-based Network Access Control

Alcuni riferimenti

IEEE 802.1X: <https://standards.ieee.org/ieee/802.1X/1096/>

FreeRADIUS: <https://www.freeradius.org/>

FreeRADIUS documentation: <https://wiki.freeradius.org/>

Microsoft NPS: <https://learn.microsoft.com/en-us/windows-server/networking/technologies/nps/nps-top>

LDAP RFC: <https://datatracker.ietf.org/doc/html/rfc4511>

EAP RFC: <https://datatracker.ietf.org/doc/html/rfc3748>

WPA3: <https://www.wi-fi.org/discover-wi-fi/security>